

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 16

Domain IV - Incident Management

43 Questions	69 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 69 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM4-108)

Scenario: A library network detects abuse of its federated-login service on a weekend. Its plan permits only the technology director to disable federation, but the director is unavailable for twelve hours.

Which plan enhancement would BEST enable a timely response?

- A. Require responders to wait for the director regardless of continuing harm.
- B. Define impact-based suspension authority, limits, named alternates, and escalation requirements.
- C. Authorize every employee to disable any shared service permanently.
- D. Give the identity supplier final authority for all organizational risk decisions.

Question 2 (CISM4-109)

Which change MOST warrants immediate review of the incident response plan rather than waiting for its annual cycle?

- A. A divestiture changes service ownership, data locations, contacts, and notification responsibilities.
- B. The help desk changes its internal shift-meeting time.
- C. A monthly report receives a new cover page.
- D. Employees receive newer monitors under a routine refresh.

Question 3 (CISM4-110)

Scenario: A city outsources operation of its parking platform and payment gateway to different providers. Each contract mentions incident support, but no party is assigned to consolidate facts or coordinate containment.

Which readiness measure is MOST appropriate?

- A. Allow both providers to make independent public statements.
- B. Let whichever provider detects an alert assume permanent incident command.
- C. Define owners, authority, evidence access, information flow, and escalation interfaces.
- D. Activate the city crisis team for every provider service ticket.

Question 4 (CISM4-111)

Scenario: A media company has moved monitoring, infrastructure, and public relations to separate suppliers. Its response plan still assigns all duties to internal teams that no longer exist.

Which action would provide the STRONGEST improvement?

- A. Redesign the plan, confirm retained accountability and supplier duties, then test interfaces.
- B. Ask each supplier to follow its own plan without coordination.
- C. Assign internal audit to operate the incident command center.
- D. Add technical indicators without changing roles.

Question 5 (CISM4-112)

Scenario: A dairy producer marks cold-storage monitoring as critical but omits power telemetry, cellular communications, and the external alerting service from its dependency map.

What is the PRIMARY readiness concern?

- A. Recovery may fail because required prerequisite services are missing.
- B. The monitoring sensors may depreciate faster than expected.
- C. The response team may open too many incident tickets.
- D. Every cold-room warning will be classified as a disaster.

Question 6 (CISM4-113)

Scenario: A concert promoter's sales platform has modest impact on normal days but extreme impact during a limited presale window.

How should incident-readiness requirements address this pattern?

- A. Assign maximum severity to every platform event throughout the year.
- B. Set severity from average annual usage only.
- C. Use time-bound priority, staffing, escalation, and recovery requirements for presale periods.
- D. Base priority only on the number of application instances.

Question 7 (CISM4-114)

Scenario: An insurer has a three-hour recovery time objective for digital claims intake but has not defined how many recently submitted claims can be lost after restoration.

Which data-recovery requirement should management define NEXT?

- A. The average number of service-desk tickets per outage.
- B. A recovery point objective based on acceptable loss of claim transactions.
- C. The minimum length of a responder status meeting.
- D. The number of recovery vendors invited to each exercise.

Question 8 (CISM4-115)

Which outcome BEST demonstrates that a continuity workaround is fit for incident use?

- A. Prioritized activities operate within approved capacity, time, control, and safety tolerances.
- B. The security team performs every business task.
- C. The workaround eliminates the need for technical recovery.
- D. The workaround uses a different user interface.

Question 9 (CISM4-116)

Scenario: A consulting firm selects its collaboration platform as the emergency communication channel. The platform uses the same single sign-on service expected to be disabled during identity compromise.

Which alternate-channel recommendation is BEST?

- A. Keep the design because the collaboration service is cloud hosted.
- B. Test an alternate channel independent of the affected identity service.
- C. Increase identity alert retention without changing the channel.
- D. Require responders to communicate only after single sign-on is restored.

Question 10 (CISM4-117)

Scenario: A home-delivery company's manual dispatch process supports 20 percent of orders, while the approved minimum during an outage is 55 percent. No capacity exercise has been performed.

Which action should management take?

- A. Accept the process because some orders can be dispatched.
- B. Reduce the approved minimum without business-owner agreement.
- C. Redesign and test the workaround against the approved capacity requirement.
- D. Wait for a real outage to measure the shortfall.

Question 11 (CISM4-118)

Scenario: A retail chain's recovery plan starts point-of-sale applications before restoring internal name resolution and address management required by those applications.

Which correction is MOST appropriate?

- A. Restore foundational network services before dependent point-of-sale applications.
- B. Give all components the same recovery point objective.
- C. Restore the most visible application first regardless of dependencies.
- D. Let individual store technicians select the sequence during recovery.

Question 12 (CISM4-119)

Scenario: A property-management company declares its recovery test successful because database servers started. User authentication, payment interfaces, tenant records, and business transactions were not tested.

What should be included in the NEXT test?

- A. Only the time required to power on database hosts.
- B. A count of backup files present at the recovery site.
- C. A review of office supplies stored at the alternate location.
- D. End-to-end validation of access, data integrity, interfaces, transactions, dependencies, and recovery objectives.

Question 13 (CISM4-120)

Which BIA output is MOST directly useful when establishing a disaster recovery sequence?

- A. The personal restoration preference of each administrator.
- B. The historical purchase price of each server.
- C. Approved process criticality, recovery objectives, and mapped technology dependencies.
- D. The alphabetical order of application names.

Question 14 (CISM4-121)

Scenario: A pharmaceutical company ranks incidents by the number of systems involved. Suspected theft of one formulation-encryption key is ranked below unwanted browser extensions on many training kiosks.

How should the severity model be improved?

- A. Use only the replacement value of affected hardware.
- B. Classify every cryptographic alert at maximum severity automatically.
- C. Allow the first responder to choose any severity without guidance.
- D. Include information sensitivity, trust, criticality, scope, urgency, and legal or business consequences.

Question 15 (CISM4-122)

Scenario: A sports league tells responders to involve executives whenever an incident appears important. Exercises show that privacy counsel and event operations are contacted inconsistently.

Which replacement is BEST?

- A. Escalation only after media coverage begins.
- B. Use thresholds based on business events, safety, information, urgency, and obligations.
- C. Escalation whenever a monitoring tool creates two alerts.
- D. Board escalation for every false-positive alert.

Question 16 (CISM4-123)

Scenario: An online education provider uses one high-priority label for account misuse, service outages, content-integrity issues, and privacy events. The wrong specialists are frequently engaged.

Which redesign would BEST solve the routing problem?

- A. Retain the single label and distribute it to a larger mailing list.
- B. Create a separate severity for every course offered.
- C. Use technical repair time as the only classification field.
- D. Separate category and severity, then map combinations to roles, authority, actions, and escalation.

Question 17 (CISM4-124)

Scenario: A maritime company's exercise reveals no trained family-liaison alternate, no legal evidence coordinator, and no executive briefing owner. Technical containment performs well.

Which improvement should be prioritized?

- A. Teach executives to operate forensic tools.
- B. Remove nontechnical injects from future exercises.
- C. Map competencies to roles, designate trained primary and alternate personnel, and exercise them.
- D. Make a technology supplier responsible for all corporate decisions.

Question 18 (CISM4-125)

Scenario: A leasing company's annual incident exercise consists of technicians demonstrating that monitoring alerts appear on a dashboard. Management treats this as proof that the entire plan works.

How should this technical demonstration be expanded into a valid response exercise?

- A. Score only the number of alerts shown.
- B. Use a realistic scenario testing decisions, escalation, communications, continuity, and recovery.
- C. Exclude business leaders to avoid slowing technical work.
- D. Certify the plan solely because monitoring generated alerts.

Question 19 (CISM4-126)

Which method BEST examines leadership decisions during a complex incident while keeping live services unchanged?

- A. A surprise shutdown of production services.
- B. A technical configuration audit.
- C. A survey asking whether employees recognize the plan title.
- D. A facilitated tabletop with progressive business, legal, operational, and communication injects.

Question 20 (CISM4-127)

Scenario: An aviation-services exercise finds delayed escalation and incomplete supplier contacts. The final report records the observations but assigns no action owners or completion criteria.

What should the information security manager implement NEXT?

- A. Automatic approval of the plan because the exercise occurred.
- B. Deletion of the findings to protect participant confidence.
- C. Attendance growth as the only readiness measure.
- D. Prioritized corrective actions with owners, due dates, validation evidence, escalation, and retesting.

Question 21 (CISM4-128)

What is the PRIMARY purpose of triaging a security report?

- A. To complete every legal notification immediately.
- B. To determine incident status and establish initial impact, ownership, and routing.
- C. To prove the final root cause before containment.
- D. To redesign all affected systems before investigation.

Question 22 (CISM4-129)

Scenario: A water-treatment operator receives reports of blocked password spraying and unexplained changes to chemical-quality readings shown to operators.

Which report should be investigated FIRST?

- A. The blocked attempts because they contain more log entries.
- B. Both only after the regular weekly review.
- C. The altered quality readings because potential integrity and public-safety impact require urgent assessment.
- D. Neither until malicious intent is proven.

Question 23 (CISM4-130)

Scenario: Franchise locations report suspicious payment activity by texting regional sales representatives. Several messages are overlooked during weekends.

Which reporting-channel improvement is MOST appropriate?

- A. Provide a monitored reporting channel with acknowledgment, required intake details, and defined escalation.
- B. Ask sales representatives to conduct evidence collection on personal phones.
- C. Require franchise staff to identify the attacker before reporting.
- D. Accept weekend delays because franchise locations are independently owned.

Question 24 (CISM4-131)

Scenario: A compromised port-control system is moving an automated crane outside its authorized zone. An emergency stop may overwrite a short diagnostic buffer.

Which safety-first response should the information security manager support?

- A. Stop hazardous movement under authorized procedures and preserve other evidence.
- B. Continue crane operation until all volatile evidence is captured.
- C. Erase the controller immediately without recording changes.
- D. Ask the controller supplier whether port safety rules should apply.

Question 25 (CISM4-132)

Scenario: Evidence suggests a monitoring provider suppressed alerts that would reveal failure to meet its contract. The provider proposes investigating itself and supplying only a conclusion.

Which governance response is BEST?

- A. Appoint an appropriately independent investigator, preserve records, enforce evidence-access rights, and coordinate legal oversight.
- B. Accept the provider's conclusion because it operates the tools.
- C. Accuse the provider publicly before reviewing source evidence.
- D. Close the incident after the provider promises service credits.

Question 26 (CISM4-133)

Scenario: A supervisor photographs damaged access-control equipment, edits the image filenames, and forwards copies through multiple personal messaging accounts without retaining originals or a transfer record.

What is the PRIMARY evidentiary concern in this situation?

- A. Evidence may be challenged because integrity, provenance, and custody are unproven.
- B. The photographs prove who caused the damage.
- C. The incident automatically becomes a disaster.
- D. All access-control recovery objectives must be reduced.

Question 27 (CISM4-134)

Scenario: A regulator informally asks an analyst to preserve and send all customer communications related to an incident. The request has no documented scope or approved transfer method.

Which action should occur NEXT?

- A. Send every record through the analyst's personal account.
- B. Coordinate legal, privacy, records, and regulators on preservation and secure transfer.
- C. Delete unrelated messages before counsel reviews preservation duties.
- D. Allow the analyst to interpret legal scope alone.

Question 28 (CISM4-135)

Which consideration should have the GREATEST influence on containment strategy?

- A. The response tool used most often last year.
- B. Continuing harm, safety, business impact, evidence, authority, and recovery options.
- C. The personal preference of the incident analyst.
- D. The alphabetical position of the affected service.

Question 29 (CISM4-136)

Scenario: A travel marketplace confirms fraudulent requests using one partner's webhook credential. Disabling all partner connectivity would stop bookings across several countries.

Which containment action is BEST?

- A. Delete webhook logs before the connection is isolated.
- B. Keep the credential active until the partner's next audit.
- C. Disable every booking service without assessing narrower options.
- D. Revoke the credential, isolate the partner flow, preserve records, and monitor activity.

Question 30 (CISM4-137)

Scenario: A cargo terminal cannot update crane-management firmware for ten weeks. Network isolation and supervised local administration reduce exposure but increase turnaround time.

Which legacy-containment strategy is MOST appropriate?

- A. Restore remote administration solely to improve turnaround time.
- B. Accept the flaw permanently without accountable approval.
- C. Adopt tested, monitored, business-approved restrictions with an expiration date and tracked remediation.
- D. Disable every crane without considering safety or trade commitments.

Question 31 (CISM4-138)

Scenario: A blogger claims a retailer's loyalty database is publicly available. Responders have confirmed an exposed test server but have not found customer records on it.

Which communication action is BEST at this stage?

- A. Confirm that all loyalty records were exposed.
- B. Publish each investigator's working theory.
- C. Issue an approved holding statement with verified facts, actions, and updates.
- D. Refuse to communicate until the incident is permanently closed.

Question 32 (CISM4-139)

Scenario: A payment-services firm confirms unauthorized access affecting several products. Customer contracts, regulator expectations, and insurance conditions differ, while the affected-record count is still being refined.

What should the information security manager initiate FIRST?

- A. Map verified facts to legal, contractual, insurer, and customer requirements.
- B. One universal deadline based on the strictest clause found.
- C. A public claim that every product lost customer data.
- D. A delay until complete root-cause analysis is approved.

Question 33 (CISM4-140)

Scenario: During a hosted-service incident, auditors receive vague status summaries while executives receive thousands of control events. Both groups lack the information needed for their roles.

Which communication design would MOST improve oversight?

- A. Tailor reports from one authoritative record to decisions and update schedules.
- B. Send every stakeholder the same raw event export.
- C. Permit teams to use independent scope estimates.
- D. Stop routine updates and answer only ad hoc requests.

Question 34 (CISM4-141)

Scenario: A cyber incident disables fare payment and real-time passenger information across a metropolitan transit network during peak travel. Routine technical calls exclude crisis leadership and public communications.

Which crisis-escalation action should occur NEXT?

- A. Wait until the technical root cause is final.
- B. Allow individual technicians to brief passengers and media.
- C. Close the incident because transit operations own passenger impact.
- D. Activate crisis coordination for operational, executive, government, customer, and public communication needs.

Question 35 (CISM4-142)

Scenario: A digital agency has clean application backups, but the infrastructure templates used to rebuild them may contain the unauthorized settings that enabled the incident.

What should occur before restoration?

- A. Use the templates immediately because application backups are clean.
- B. Discard every backup and rebuild from memory.
- C. Validate and correct the complete recovery baseline in isolation.
- D. Restore directly into production and test after customer access resumes.

Question 36 (CISM4-143)

What is the PRIMARY purpose of validating a restored service before normal operation?

- A. To eliminate the need for monitoring after recovery.
- B. To guarantee that no future security event is possible.
- C. To confirm functionality, integrity, security, dependencies, and agreed business acceptance criteria.
- D. To let a supplier accept all organizational risk.

Question 37 (CISM4-144)

Scenario: A membership platform has been rebuilt after unauthorized balance changes. Technical checks pass, but totals still differ from the authoritative finance ledger.

Which decision is MOST appropriate?

- A. Resume transactions because the application is online.
- B. Retain restrictions until validation is complete and the owner accepts service.
- C. Allow the hosting provider to accept the financial discrepancy.
- D. Declare recovery solely because the time objective has elapsed.

Question 38 (CISM4-145)

Scenario: An airline can securely restore crew scheduling, but management reporting depends on a data interface that has not passed security validation.

Which recovery approach should be used?

- A. Reconnect all interfaces to announce full recovery.
- B. Keep crew scheduling offline until reporting is ready.
- C. Restore validated scheduling gradually and communicate remaining limitations.
- D. Permit each application team to reconnect components independently.

Question 39 (CISM4-146)

Scenario: A customer-service assistant exposed internal guidance after crafted prompts bypassed expected boundaries. The review finds that prior scenarios covered only conventional data extraction and that escalation criteria omit generated responses.

Which improvement package is BEST?

- A. Record the incident but retain current risk and response assumptions.
- B. Disable all automated assistance permanently without business evaluation.
- C. Rely only on employee reminders without changing technical or response measures.
- D. Reassess exposure, improve safeguards, train roles, and test new scenarios.

Question 40 (CISM4-147)

Scenario: After a database exposure, a director wants the review to identify only the administrator who approved the last change.

How should the information security manager reframe the review?

- A. Analyze design, approval, workload, and oversight while handling personnel matters separately.
- B. Begin by announcing individual fault to all staff.
- C. Cancel the review because personnel action may occur.
- D. Exclude change and database process owners.

Question 41 (CISM4-148)

Scenario: Authentication failed across several services after time drift exceeded tolerance. The review finds that the authoritative time source was removed during a project, monitoring ownership was unclear, and no dependency check occurred.

Which statement BEST identifies the root cause?

- A. Employees received authentication error messages.
- B. Dependency governance failed to preserve ownership, monitoring, and authoritative-time validation.
- C. Responders restarted several identity servers.
- D. The service desk received unusually high call volume.

Question 42 (CISM4-149)

Scenario: A nonprofit's incident review produced twelve recommendations, but they remain in meeting minutes with no priority, owner, target date, validation, or exception process.

What should be implemented?

- A. Verbal confirmation from teams without supporting evidence.
- B. Automatic closure when the incident reaches its anniversary.
- C. A rule that only the original incident commander may review progress.
- D. A tracked action register with owners, deadlines, validation, escalation, and risk acceptance.

Question 43 (CISM4-150)

Scenario: An energy cooperative reports only monthly incident counts. Leadership cannot determine whether impact, detection delays, repeated causes, recovery performance, or overdue actions are improving.

Which metric set is MOST useful?

- A. Only the number of alerts received from each site.
- B. Trends in impact, containment time, recurrence, recovery, and remediation aging.
- C. Only the percentage of records marked closed.
- D. Only total responder hours.

Answer Key

Domain IV - Incident Management

1 B	2 A	3 C	4 A	5 A
6 C	7 B	8 A	9 B	10 C
11 A	12 D	13 C	14 D	15 B
16 D	17 C	18 B	19 D	20 D
21 B	22 C	23 A	24 A	25 D
26 A	27 B	28 B	29 D	30 C
31 C	32 A	33 A	34 D	35 C
36 C	37 B	38 C	39 D	40 A
41 B	42 D	43 B		

Detailed Explanations

Question 1 (CISM4-108)

Correct answer: B - Define impact-based suspension authority, limits, named alternates, and escalation requirements.

Defined delegation and alternates allow proportionate action without abandoning accountability. Waiting may extend harm, unrestricted employee authority is excessive, and the organization cannot transfer its final risk decision to a supplier.

Question 2 (CISM4-109)

Correct answer: A - A divestiture changes service ownership, data locations, contacts, and notification responsibilities.

A divestiture can alter scope, ownership, dependencies, contacts, and legal duties, so the plan must be reviewed promptly. Cosmetic reporting, meeting schedules, and routine hardware refreshes do not materially change response governance.

Question 3 (CISM4-110)

Correct answer: C - Define owners, authority, evidence access, information flow, and escalation interfaces.

A coordinated structure preserves organizational authority and creates usable interfaces among providers. Independent communication fragments facts, initial detection does not establish command, and activating crisis leadership for every ticket is disproportionate.

Question 4 (CISM4-111)

Correct answer: A - Redesign the plan, confirm retained accountability and supplier duties, then test interfaces.

The operating model requires redesigned roles, accountability, information access, and tested interfaces. More indicators do not repair governance, independent supplier plans create gaps, and internal audit should not take an operational command role.

Question 5 (CISM4-112)

Correct answer: A - Recovery may fail because required prerequisite services are missing.

Unmapped prerequisites can make a stated critical-service recovery sequence impossible. Ticket volume and depreciation are unrelated to service viability, and dependency gaps do not automatically turn every warning into a disaster.

Question 6 (CISM4-113)

Correct answer: C - Use time-bound priority, staffing, escalation, and recovery requirements for presale periods.

Event-driven requirements reflect when interruption creates the greatest business harm. Annual averages can hide the peak, permanent maximum severity is inefficient, and instance count does not measure business impact.

Question 7 (CISM4-114)

Correct answer: B - A recovery point objective based on acceptable loss of claim transactions.

The RPO defines acceptable data loss and complements the time objective. Ticket volume, meeting length, and vendor attendance do not specify how far restored claim data may roll back.

Question 8 (CISM4-115)

Correct answer: A - Prioritized activities operate within approved capacity, time, control, and safety tolerances.

Continuity is effective when prioritized work remains within approved tolerances during disruption. Interface differences and security ownership do not prove success, and a workaround supports rather than eliminates technical recovery.

Question 9 (CISM4-116)

Correct answer: B - Test an alternate channel independent of the affected identity service.

An emergency channel must remain usable when primary identity is unavailable and should be tested. Cloud hosting does not remove the shared dependency, longer alert retention does not restore access, and delayed communication undermines response.

Question 10 (CISM4-117)

Correct answer: C - Redesign and test the workaround against the approved capacity requirement.

The known capacity gap should be corrected and tested or explicitly handled through accountable risk decisions. Accepting it, silently lowering requirements, or waiting for an actual incident leaves a foreseeable continuity failure unresolved.

Question 11 (CISM4-118)

Correct answer: A - Restore foundational network services before dependent point-of-sale applications.

Foundational name and address services must operate before dependent applications can function. Equal RPOs do not fix order, visibility does not override prerequisites, and decentralized improvisation conflicts with approved recovery priorities.

Question 12 (CISM4-119)

Correct answer: D - End-to-end validation of access, data integrity, interfaces, transactions, dependencies, and recovery objectives.

Server startup is only a component result. End-to-end validation demonstrates that the recovered business service is usable and trustworthy; host timing, file counts, and office supplies cannot establish that outcome.

Question 13 (CISM4-120)

Correct answer: C - Approved process criticality, recovery objectives, and mapped technology dependencies.

Criticality, objectives, and dependencies translate business needs into a workable restoration sequence. Purchase price, individual preference, and alphabetical order do not reflect tolerable impact or service prerequisites.

Question 14 (CISM4-121)

Correct answer: D - Include information sensitivity, trust, criticality, scope, urgency, and legal or business consequences.

Impact-based dimensions capture the severe consequences of a single critical key. Hardware value and responder preference are inadequate, while automatic maximum ratings ignore the facts and proportionality of each case.

Question 15 (CISM4-122)

Correct answer: B - Use thresholds based on business events, safety, information, urgency, and obligations.

Defined impact and obligation thresholds create consistent, timely routing. Media coverage is a late trigger, alert counts do not express consequence, and sending every false positive to the board overwhelms governance.

Question 16 (CISM4-123)

Correct answer: D - Separate category and severity, then map combinations to roles, authority, actions, and escalation.

Category and severity together provide type and impact information needed for proper routing. Course-level severity is unmanageable, repair time omits nontechnical consequences, and broader distribution does not correct ambiguity.

Question 17 (CISM4-124)

Correct answer: C - Map competencies to roles, designate trained primary and alternate personnel, and exercise them.

The gaps concern cross-functional roles and resilience, so competency mapping, training, alternates, and retesting directly address them. Technical executive training, narrower exercises, or outsourced corporate decisions would not fix the readiness weakness.

Question 18 (CISM4-125)

Correct answer: B - Use a realistic scenario testing decisions, escalation, communications, continuity, and recovery.

A realistic objective-driven exercise tests the cross-functional capabilities on which the plan depends. Alert demonstrations validate only a narrow control, and excluding leaders or declaring broad success would create false assurance.

Question 19 (CISM4-126)

Correct answer: D - A facilitated tabletop with progressive business, legal, operational, and communication injects.

A facilitated tabletop safely challenges leadership judgment and coordination across an evolving scenario. A live shutdown creates risk, an audit tests configurations, and plan recognition does not demonstrate decision capability.

Question 20 (CISM4-127)

Correct answer: D - Prioritized corrective actions with owners, due dates, validation evidence, escalation, and retesting.

Exercise findings require accountable remediation and evidence that changes work. Deleting findings, relying on attendance, or treating completion as validation prevents the organization from closing known readiness gaps.

Question 21 (CISM4-128)

Correct answer: B - To determine incident status and establish initial impact, ownership, and routing.

Triage decides whether reported activity qualifies as an incident and initiates appropriate priority and ownership. Notification, root cause, and permanent redesign depend on additional facts and later phases.

Question 22 (CISM4-129)

Correct answer: C - The altered quality readings because potential integrity and public-safety impact require urgent assessment.

Potentially false operational readings can create immediate safety consequences and therefore deserve priority. Log volume is not equivalent to impact, and waiting for routine review or proven intent may allow harm.

Question 23 (CISM4-130)

Correct answer: A - Provide a monitored reporting channel with acknowledgment, required intake details, and defined escalation.

A monitored channel supports timely, consistent intake and escalation across distributed locations. Attribution requirements delay reporting, personal-phone evidence collection is inappropriate, and ownership arrangements do not remove shared incident exposure.

Question 24 (CISM4-131)

Correct answer: A - Stop hazardous movement under authorized procedures and preserve other evidence.

Life and operational safety comes first, while documentation and feasible evidence preservation should continue. Keeping hazardous equipment active is unacceptable, undocumented erasure harms investigation, and the organization retains safety authority.

Question 25 (CISM4-132)

Correct answer: D - Close the incident after the provider promises service credits.

Potential provider involvement requires independent fact finding, preservation, contractual access, and legal coordination. Tool access does not eliminate conflict, service credits do not establish cause, and premature accusation creates additional risk.

Question 26 (CISM4-133)

Correct answer: A - Evidence may be challenged because integrity, provenance, and custody are unproven.

Uncontrolled editing and transfer weaken proof of authenticity and handling. The photographs do not by themselves establish attribution, define a disaster, or justify unrelated recovery-objective changes.

Question 27 (CISM4-134)

Correct answer: B - Coordinate legal, privacy, records, and regulators on preservation and secure transfer.

Specialist coordination ensures the request is authoritative, scoped, preserved, and handled securely. Informal transfer, analyst-only legal judgment, or premature deletion can create privacy, custody, and compliance failures.

Question 28 (CISM4-135)

Correct answer: B - Continuing harm, safety, business impact, evidence, authority, and recovery options.

Containment is a risk-based decision that balances harm reduction with operational, safety, evidentiary, authority, and recovery needs. Tool history, personal preference, and service naming do not determine proportionality.

Question 29 (CISM4-136)

Correct answer: D - Revoke the credential, isolate the partner flow, preserve records, and monitor activity.

Targeted revocation stops the confirmed path while limiting collateral impact and preserving evidence. Delay allows continuing abuse, platform-wide shutdown may be disproportionate, and deleting logs impairs investigation.

Question 30 (CISM4-137)

Correct answer: C - Adopt tested, monitored, business-approved restrictions with an expiration date and tracked remediation.

A tested, approved, monitored, time-limited containment strategy balances operational need with reduced exposure until remediation. Convenience alone does not justify exposure, indefinite acceptance lacks governance, and wholesale shutdown may be disproportionate.

Question 31 (CISM4-138)

Correct answer: C - Issue an approved holding statement with verified facts, actions, and updates.

A verified holding statement supports timely transparency without speculation. Confirming unsupported impact or publishing theories creates misinformation, while prolonged silence can amplify confusion during a visible event.

Question 32 (CISM4-139)

Correct answer: A - Map verified facts to legal, contractual, insurer, and customer requirements.

Notification assessment should begin promptly using verified facts and obligations applicable to each relationship. Universal deadlines may be wrong, broad impact claims may be unsupported, and full root cause is not required to begin timely assessment.

Question 33 (CISM4-140)

Correct answer: A - Tailor reports from one authoritative record to decisions and update schedules.

A shared authoritative record maintains consistency, while tailored reporting makes information actionable. Identical raw data creates noise, independent estimates conflict, and ad hoc-only communication weakens coordinated oversight.

Question 34 (CISM4-141)

Correct answer: D - Activate crisis coordination for operational, executive, government, customer, and public communication needs.

Widespread public-service disruption requires coordinated crisis leadership while technical response continues. Waiting for root cause delays action, independent briefings create inconsistency, and operational ownership does not end the cyber incident.

Question 35 (CISM4-142)

Correct answer: C - Validate and correct the complete recovery baseline in isolation.

A trustworthy recovery requires clean applications and infrastructure configuration, not data backups alone. Immediate production use risks recurrence, discarding all backups is unsupported, and post-release testing exposes customers to avoidable harm.

Question 36 (CISM4-143)

Correct answer: C - To confirm functionality, integrity, security, dependencies, and agreed business acceptance criteria.

Validation establishes that the service is trustworthy and fit for business use. It cannot guarantee zero future events, does not replace monitoring, and does not transfer accountable acceptance to a supplier.

Question 37 (CISM4-144)

Correct answer: B - Retain restrictions until validation is complete and the owner accepts service.

Availability does not establish data integrity. Restrictions should remain until reconciliation and authorized business acceptance; a provider cannot accept the organization's business risk, and a time objective does not override failed validation.

Question 38 (CISM4-145)

Correct answer: C - Restore validated scheduling gradually and communicate remaining limitations.

Phased recovery restores the critical validated function while controlling the unresolved interface risk. Full reconnection weakens assurance, delaying scheduling increases impact, and independent actions bypass recovery coordination.

Question 39 (CISM4-146)

Correct answer: D - Reassess exposure, improve safeguards, train roles, and test new scenarios.

The review should drive updated risk assumptions, safeguards, response criteria, training, and testing. No change forfeits learning, reminders alone are incomplete, and permanent blanket removal may be disproportionate.

Question 40 (CISM4-147)

Correct answer: A - Analyze design, approval, workload, and oversight while handling personnel matters separately.

A systemic review identifies conditions that can be improved and preserves candor, while individual accountability follows appropriate personnel processes. Exclusion, public blame, or cancellation leaves organizational weaknesses unresolved.

Question 41 (CISM4-148)

Correct answer: B - Dependency governance failed to preserve ownership, monitoring, and authoritative-time validation.

The governance failure explains why removal of a shared dependency led to widespread authentication problems. Error messages and calls are symptoms, while restarts are response actions rather than the underlying cause.

Question 42 (CISM4-149)

Correct answer: D - A tracked action register with owners, deadlines, validation, escalation, and risk acceptance.

A governed register converts lessons into accountable, verifiable improvement and exposes residual-risk decisions. Elapsed time, unsupported claims, and narrow oversight do not demonstrate that corrective action is effective.

Question 43 (CISM4-150)

Correct answer: B - Trends in impact, containment time, recurrence, recovery, and remediation aging.

Balanced metrics connect incident activity to business consequence, operational effectiveness, repeated causes, recovery, and remediation. Alert, labor, and closure counts alone can mask deteriorating risk or incomplete improvement.